

Cybersecurity requirements for routers, modems intended for the connection to the internet, and switches

Deep Dive Session

EN 304 627

Presented by: Bruno Banelli
December 2025



Agenda

Session Overview

- CRA & Standardisation Request Overview
- STAN4CR2 Project Context
- Standard Scope & Document Structure
- Risk Factor Framework (Clause 4.8)

Deep Dive Content

- Technical Requirements (Clause 5)
- Assessment & Verification (Clause 7)
- Compliance Demonstration
- Areas for Stakeholder Feedback

CRA & Standardisation Request Overview

Cyber Resilience Act Purpose

- CRA ensures products with digital elements are secure by design and resilient against cyber threats throughout their lifecycle.

Key Focus for Routers, Modems, Switches

- Not about basic functionalities - cybersecurity requirements

Harmonized Standards Benefits

- Reduce market fragmentation and help manufacturers efficiently meet regulatory expectations across the EU.
- Ensuring products are secure by design
- Identifying and mitigating vulnerabilities

STAN4CR2 Project Context

Harmonized Standards Development

- STAN4CR2 focuses on creating cybersecurity standards for different vertical products with digital elements to ensure CRA compliance.

Organizational Leadership and Funding

- ETSI leads the project through TC CYBER with funding from the European Commission and support from ENISA.

Collaborative Approach

- The project fosters collaboration amongst industry, regulators, and academia to address cybersecurity challenges and align with EU regulations.

ETSI EN 304 627 Scope

Product Coverage

- Routers
- Modems for internet connection
- Switches

CRA Classification: Class I products under Annex III, point 12

Out of Scope

- Unmanaged products with fixed functionality and no configuration interface or administrative access.

Product Context

Intended Purpose & Product Definitions (4.1–4.4)

- Establishes what routers, modems, and switches are and their fundamental role in network connectivity.

Product Functions & Architecture (4.5–4.6)

- Multi-plane architecture (data, control, management planes) and core functions.

Operational Environments (4.7): Seven deployment types

Risk Assessment Framework (4.8): 21 risk factors in five categories

Users & Use Cases (4.9–4.10): Eight foreseeable deployment scenarios

Risk Assessment Framework: Introduction

Two-Component Approach

- Risk Factors (Clause 4.8.2) — Cybersecurity risks manufacturers shall evaluate based on intended purpose, foreseeable use, and conditions of use
- Risk Factor Assessment (Clause 4.8.3) — Document which risk factors apply: Applicable (Default), Applicable (Configurable), Not Applicable

Result

- Risk factors present in the product trigger corresponding security requirements in Clause 5.

Five Risk Factor Categories

Baseline (BL-RF) — Clause 4.8.2.1 — 7 factors

- Fundamental security properties for ALL products

Management Access (MA-RF) — Clause 4.8.2.2 — 4 factors

Management Operational (MO-RF) — Clause 4.8.2.3 — 2 factors

Protocol Implementation (PI-RF) — Clause 4.8.2.4 — 7 factors

Data Operations (DO-RF) — Clause 4.8.2.5 — 1 factor

Total: 21 Risk Factors

Baseline Risk Factors Summary

Why Baseline Factors Are Universal

- Apply to ALL routers, modems, and switches regardless of deployment
- Address fundamental security properties: defaults, lifecycle, availability, integrity, packets, exposure, visibility
- Foundational defence against undiscovered exploitable vulnerabilities

Triggered Requirements Are Unconditional

- No configuration or deployment scenario exempts products from these controls
- Ensures minimum security baseline across the entire product category

Baseline Risk Factors - Part 1

[BL-RF-1] Initial configuration risk factor

- Products shipped with insecure default configurations face immediate exploitation. Attackers scan for default credentials within minutes.

[BL-RF-2] Lifecycle transition risk factor

- Products retaining data during decommissioning expose credentials, keys, and topology to unauthorised parties.

[BL-RF-3] Availability disruption risk factor

- Network infrastructure failures cascade through dependent systems. Products lacking resilience fail completely under attack.

Baseline Risk Factors - Part 2

[BL-RF-4] System integrity compromise risk factor

- Boot process compromise enables persistent implants surviving software remediation. Products booting unsigned firmware cannot distinguish legitimate from malicious updates.

[BL-RF-5] Packet processing risk factor

- Products process millions of packets daily. Attackers craft malformed packets triggering buffer overflows, memory corruption, or undefined behaviour.

[BL-RF-7] Security event visibility risk factor

- Products lacking comprehensive audit logging operate as security blind spots. Products failing to persist logs across resets eliminate forensic evidence.

[BL-RF-6] Attack surface exposure risk factor

- Every exposed interface represents a potential attack vector. Debug interfaces (JTAG, UART, SWD) provide complete system control through physical access.

Management Access Risk Factors

[MA-RF-1] Physical access exploitation risk factor

- Physical-only management interfaces create unaudited configuration risk through console ports, USB, or serial connections.

[MA-RF-2] Local network compromise risk factor

- Local network management creates insider threat opportunities without crossing security boundaries.

[MA-RF-3] Internal network traversal risk factor

- Routable management interfaces enable lateral movement across VLANs, VPNs, and WAN links.

[MA-RF-4] Global internet exposure risk factor

- Internet-accessible management creates continuous attack surface for global adversaries.

Management Operational Risk Factors

[MO-RF-1] Manual administration risk factor

- Applies when products support individual manual administration without NMS integration.
- Security patches remain uninstalled, configurations drift, changes lack audit trails.

[MO-RF-2] Centralised management compromise risk factor

- Applies when products support connection to network management systems or cloud platforms.
- Management systems become single points of catastrophic failure enabling fleet-wide compromise.

Protocol Implementation Risk Factors - Part 1

[PI-RF-1] Cleartext credential risk factor

- Unencrypted protocols leak credentials across networks.

[PI-RF-2] Unauthenticated request processing risk factor

- Open endpoints enable resource exhaustion and amplification attacks.

[PI-RF-3] Information disclosure risk factor

- Discovery protocols reveal topology, versions, services without authentication.

[PI-RF-4] Weak cryptography exploitation risk factor

- Outdated algorithms guarantee future compromise.

Protocol Implementation Risk Factors Part 2

[PI-RF-5] Unverified trust establishment risk factor

- Protocols without cryptographic verification enable network manipulation, route hijacking, device impersonation.

[PI-RF-6] Post-authentication cleartext risk factor

- Authenticated but unencrypted sessions enable session theft and command injection.

[PI-RF-7] Cryptographic session compromise risk factor

- Even encrypted protocols suffer implementation vulnerabilities: weak RNG, side channels, protocol-specific weaknesses.

Data Operations Risk Factors

[DO-RF-1] Data transfer risk factor

- Applies when product supports configuration backup/restore, log export, firmware upload, or any file import/export operations.
- Data export functions leak sensitive configuration including credentials, network topology, and security policies.
- Attackers inject malicious configurations through import functions
- Upload backdoored firmware; exfiltrate operational data
- Unvalidated imports enable arbitrary code execution

Baseline vs. Conditional: Why It Matters

Baseline Risk Factors [BL-RF-1] through [BL-RF-7]

- Apply universally to ALL products
- Make triggered requirements unconditional
- Every router, modem, and switch should meet these requirements

Conditional Risk Factors [MA-RF], [MO-RF], [PI-RF], [DO-RF]

- Apply based on product characteristics and deployment context
- Only applicable when risk factor is present

Risk Factor Mapping Table

Baseline Factors → Triggered Requirements

- BL-RF-1 (Initial config) → [DEFAULT-RQ-*]
- BL-RF-2 (Lifecycle) → [RESET-RQ-*]
- BL-RF-3 (Availability) → [AVAIL-RQ-*]
- BL-RF-4 (Integrity) → [INTEGRITY-RQ-*]
- BL-RF-5 (Packet) → [PACKET-RQ-*]
- BL-RF-6 (Attack surface) → [EXPOSURE-RQ-*]
- BL-RF-7 (Visibility) → [LOG-RQ-*]

Requirement Groups Overview (Clause 5)

Core Security Controls

- [DEFAULT] 5.4.1 — Secure by default configuration
- [RESET] 5.4.2 — Factory reset mechanisms
- [UPDATE] 5.5.1 — Security update mechanisms
- [AUTH-1/2/3/4] 5.6 — Authentication, authorisation, sessions

Protection & Monitoring

- [DATA] 5.7 — Data protection
- [AVAIL] 5.8 — Availability and resilience
- [INTEGRITY/PACKET/EXPOSURE] 5.9 — Attack surface mitigation
- [LOG] 5.10 — Monitoring and logging

DEFAULT Requirements Overview - Part 1

[DEFAULT-1-RQ-1-01]

- Applicable requirements may only be disabled in factory default state when enabled would render initial setup non-functional, and omissions documented.

[DEFAULT-1-RQ-1-02]

- In factory default state, utilise only network interfaces and services necessary for product setup.

[DEFAULT-1-RQ-1-03]

- During initialization, limit access to accounts with initialization permissions.

DEFAULT Requirements Overview - Part 2

[DEFAULT-1-RQ-1-07]

- In factory default state, enforce change of administrative credentials.

[DEFAULT-1-RQ-1-08]

- Before initialization, have debugging and diagnostic interfaces disabled.

[DEFAULT-1-RQ-1-10]

- Configure all cryptographic functions to use compliant algorithms and key lengths.

[DEFAULT-1-RQ-1-11]

- Disable any protocols or services with known exploitable vulnerabilities.

RESET Requirements Overview

[RESET-1-RQ-1-01]

- Provide factory reset mechanism that restores secure-by-default configuration.

[RESET-1-RQ-1-02]

- Factory reset maintains currently installed firmware version and all applied security updates.

[RESET-1-RQ-1-03]

- Require authentication and authorisation at highest privilege level for software-initiated factory reset.

[RESET-1-RQ-1-04]

- Upon factory reset, not retain any information that could reconstruct previous configuration.

Assessment Procedure Structure (Clause 7)

Components for each requirement:

- Requirement Statement
- Activities - Step-by-step verification: review documentation, examine config, test functionality
- Verdict - Clear pass/fail criteria
- Supporting Evidence - Required documentation: manufacturer docs, configuration files, test results, log entries

Assessment Example: Factory Reset

[RESET-1-RQ-1-01] Verify factory reset restores secure-by-default configuration.

Activities:

- Manufacturer documentation describes reset mechanism and location
- Reset accessible through documented methods
- All security settings restored; user data removed

Verdict

- PASS: Mechanism available, documented; restores secure defaults; user config removed; product operates correctly.
- FAIL: Mechanism unavailable; configuration not restored; user data persists.

Compliance Demonstration Process

Step 1: Risk Factor Determination (Clause 4.8.3)

- Manufacturer assesses all 21 risk factors from Clauses 4.8.2.1–4.8.2.5

Step 2: Requirements Mapping (Clause 4.8.5)

- Using mapping table: baseline → unconditional; conditional → when present

Step 3: Risk Factor Assessment Documentation

- Include in technical documentation and Declaration of conformity

Step 4: Evidence Collection

- For each applicable requirement: documentation, test results, configurations

Compliance Demonstration: Example Product

Product: Consumer router with internet management interface

Applicable Risk Factors:

- All 7 baseline [BL-RF-1] through [BL-RF-7]
- [MA-RF-2] Local network + [MA-RF-4] Internet-exposed management
- [MO-RF-1] Manual administration
- [PI-RF-1] Cleartext protocols + [DO-RF-1] Config backup/restore

Triggered Requirement Groups:

- [DEFAULT], [RESET], [UPDATE], [AUTH-1/3/4], [DATA], [AVAIL], [INTEGRITY], [PACKET], [EXPOSURE], [LOG], [TRANSFER]

Key Principles

Design Philosophy

- Each requirement analysed for feasibility - implementation costs considered
- Risk factors create natural consequences
- Standard allows product diversity - simple products face fewer conditional requirements

Implementation Approach

- Requirements are objective and testable - third-party assessors can verify consistently
- Lifecycle perspective - compliance continues through updates and product evolution
- Based on real threat landscape - Annex B addresses actual vulnerabilities

Areas Requiring Stakeholder Feedback

Your input is critical for:

- Risk factor completeness - additional product vulnerabilities to address?
- Requirement feasibility - implementable and cost-effective?
- Assessment procedures - verification methods clear and executable?
- Cross-vertical alignment - common approaches for cryptography, updates, SBOM, auth
- Product scope boundaries - clear managed vs unmanaged distinction

No clause is written in stone - all may be improved based on industry expertise.

How to Participate

Access Draft Documents

- ETSI Open Area: <https://docbox.etsi.org/CYBER/EUSR/Open>

Collaborative Technical Discussion

ETSI Labs: <https://labs.etsi.org/rep/stan4cra>

Active Stakeholder Engagement

- Submit comments and propose improvements
- Engage in debates to refine standards
- Participate in open consultations

Q&A





Thank you for your attention!



Follow us on:

